ICT2203

Network Security

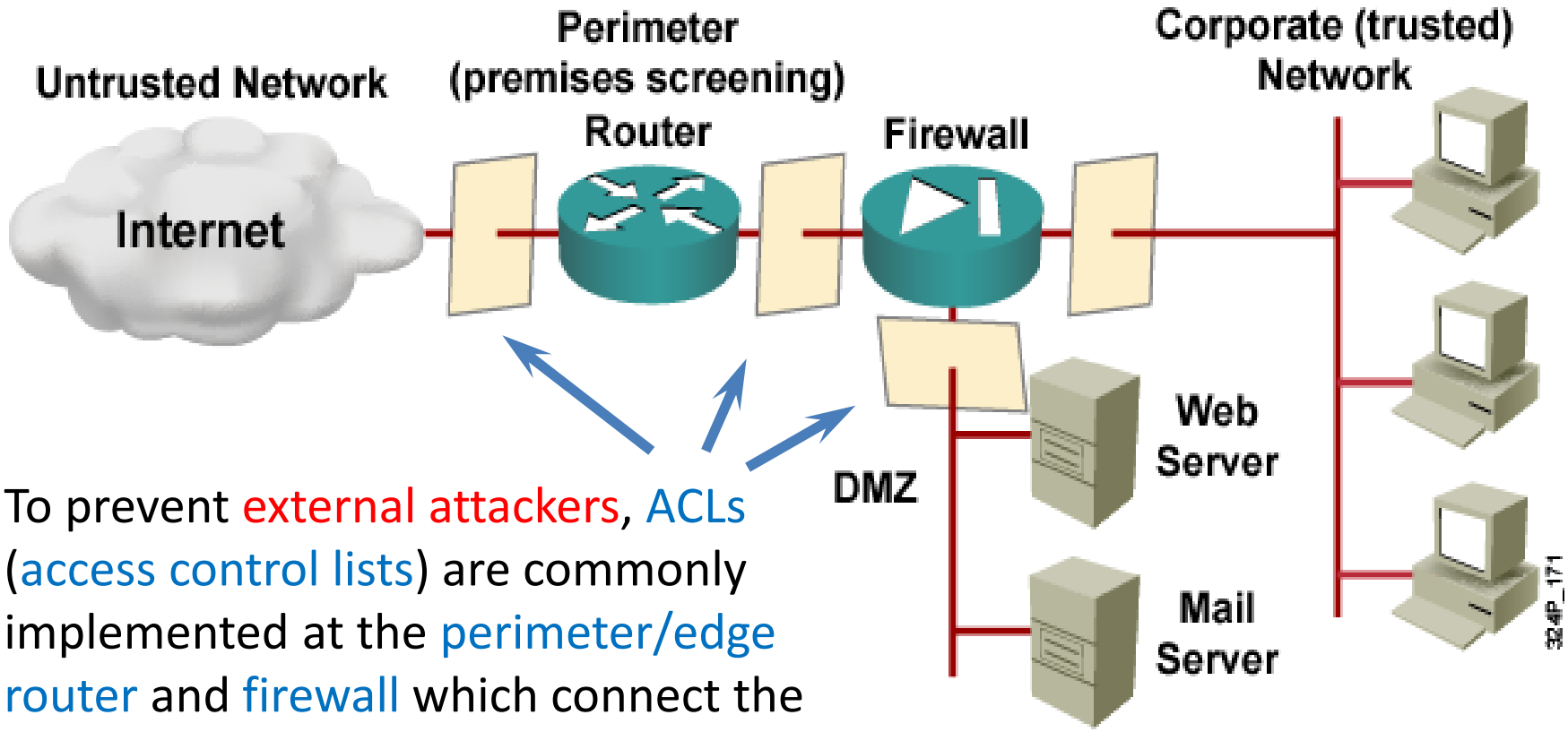
SINGAPORE INSTITUTE OF TECHNOLOGY

Lab 5 Notes:

Attacks and Defense of IP Networks with Routers

2021-2022 Trimester 1

In contrast to internal attacks, the first point of entry for external attackers are typically the routers or firewalls.



To prevent external attackers, ACLs (access control lists) are commonly implemented at the perimeter/edge router and firewall which connect the enterprise network to the Internet.

Lab Exercise 1

1.1 Network probing and scanning attack

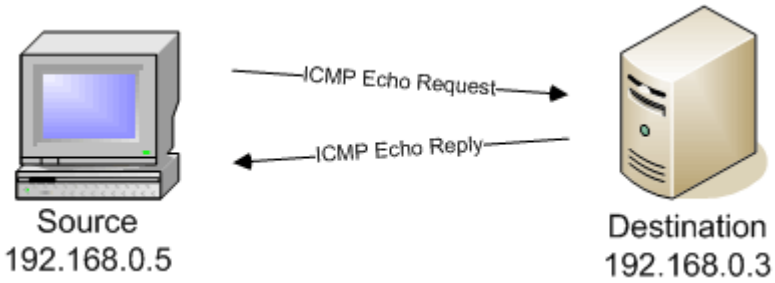
1.2 Defense:

- Minimise using suitable ACLs in routers

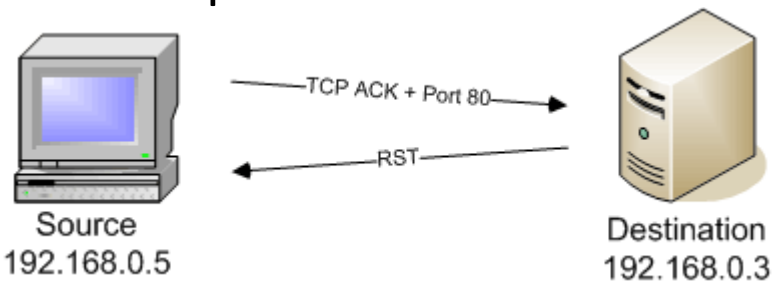
A potential external attack is reconnaissance attack, specifically network probing and port scanning attacks to discover targets which are covered in ICT2204 Ethical Hacking.

Technically, network probing and scanning attacks are based on sending ARP, ICMP, TCP or UDP requests and receiving/not receiving the replies.

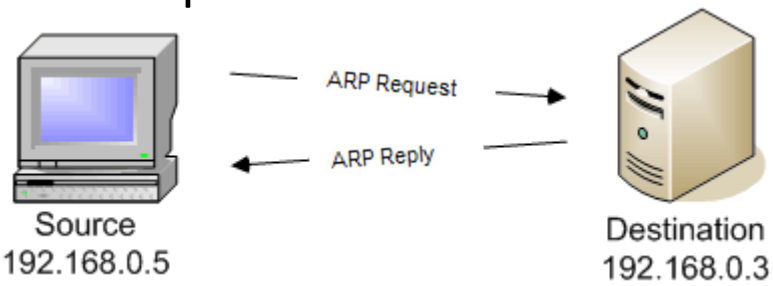
Example of ICMP scan:



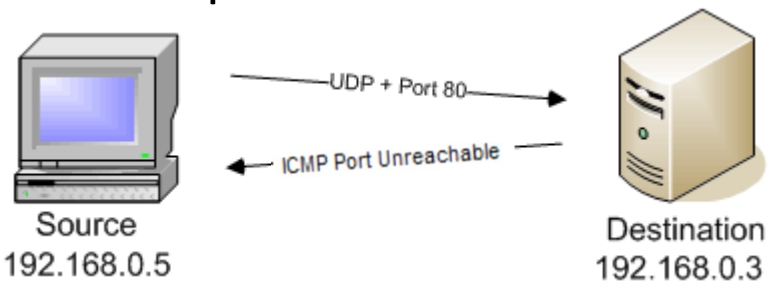
Example of TCP scan:



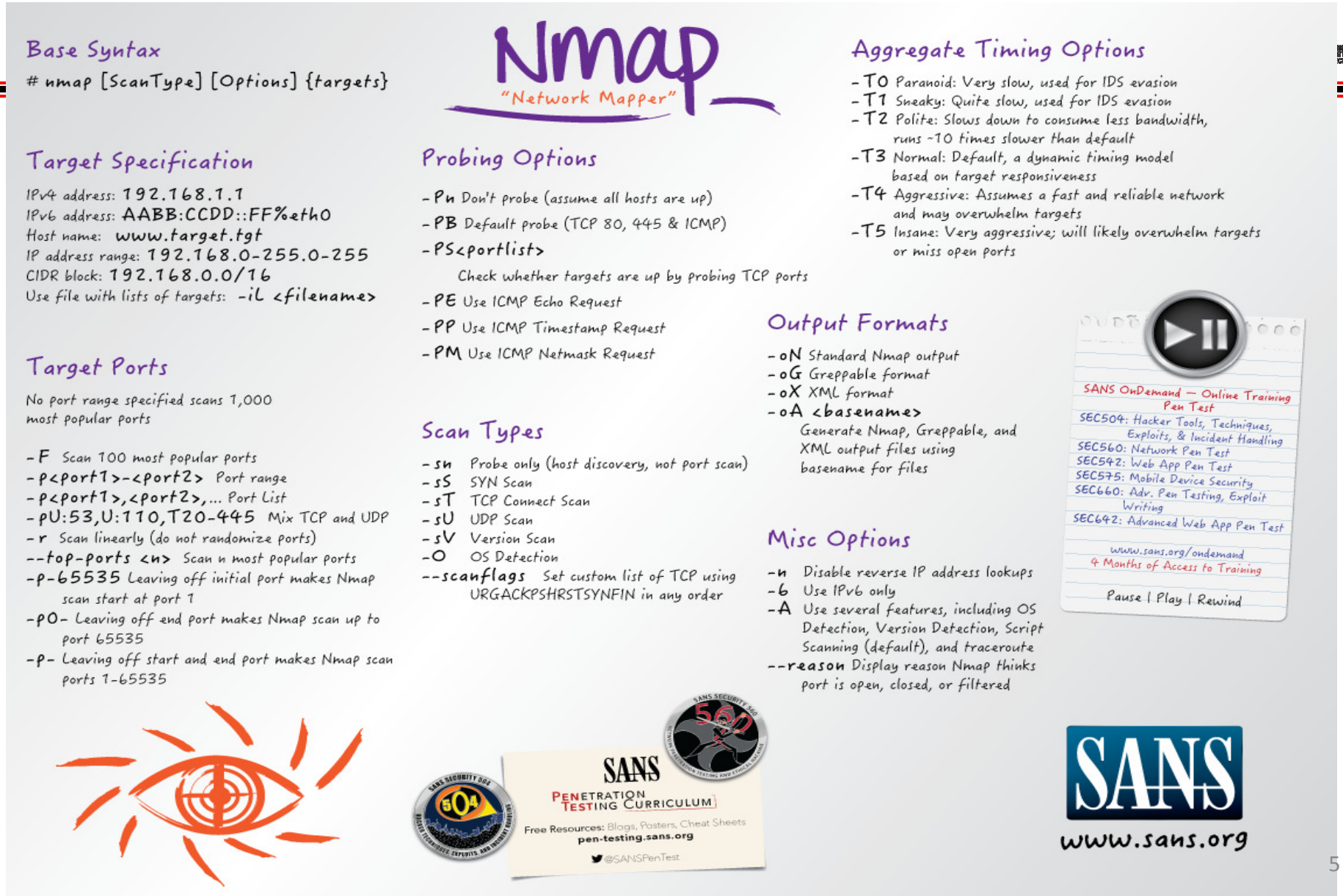
Example of ARP scan:



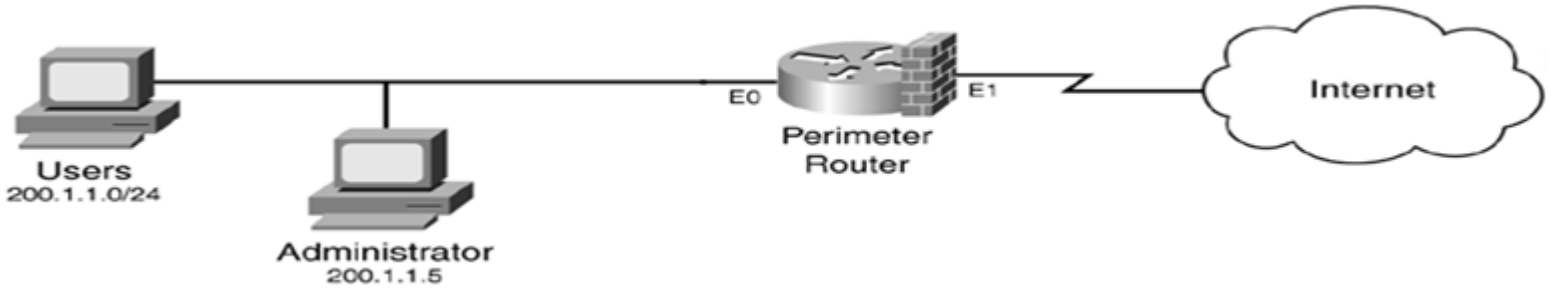
Example of UDP scan:



A useful tool for conducting network probing and scanning attacks is nmap which is available in Kali.



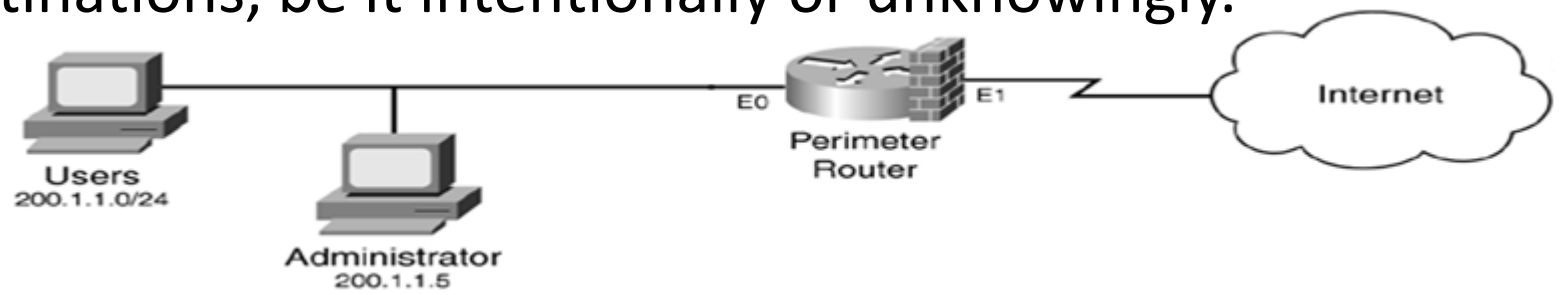
Unfortunately, it can be difficult to fully prevent network probing and scanning attacks; but some may be blocked by suitable ACLs; e.g. ingress filtering of ICMP scan as follows:




```
R1(config)# ip access-list extended nmapICMPscan-in
R1(config-ext-nacl)# deny icmp any any echo
R1(config-ext-nacl)# deny icmp any any timestamp-request
R1(config-ext-nacl)# deny icmp any any mask-request
R1(config-ext-nacl)# permit ip any any
R1(config)# interface E1
R1(config-if)# ip access-group nmapICMPscan-in in
R1(config-if)# no ip unreachables ①
```

① An attacker could gather information about your network like unused IPs and ports when scanning it. no ip unreachables will prevent your router from sending ICMP error message when dropping the packet which will leak information to attacker.

In addition, you may want to implement egress filtering of ICMP to prevent someone inside your network from scanning outside destinations, be it intentionally or unknowingly.




```
R1(config)# ip access-list extended ICMPscan-out
R1(config-ext-nacl)# permit icmp host 200.1.1.5 any echo                    ①
R1(config-ext-nacl)# permit icmp 200.1.1.0 0.0.0.255 any                    ②
error-reporting-messages
R1(config-ext-nacl)# deny icmp any any
R1(config-ext-nacl)# permit ip any any
R1(config)# interface E1
R1(config-if)# ip access-group ICMPscan-out out
```

① Allow administrator to ping which is useful for testing connectivity.

② Trade-off allowing ICMP error-reporting messages vs attacks; e.g.

- unreachable: inform client destination unavailable but exploited by UDP scan
- time-exceeded: exploited by attacker to trace route to target

Lab Exercise 2

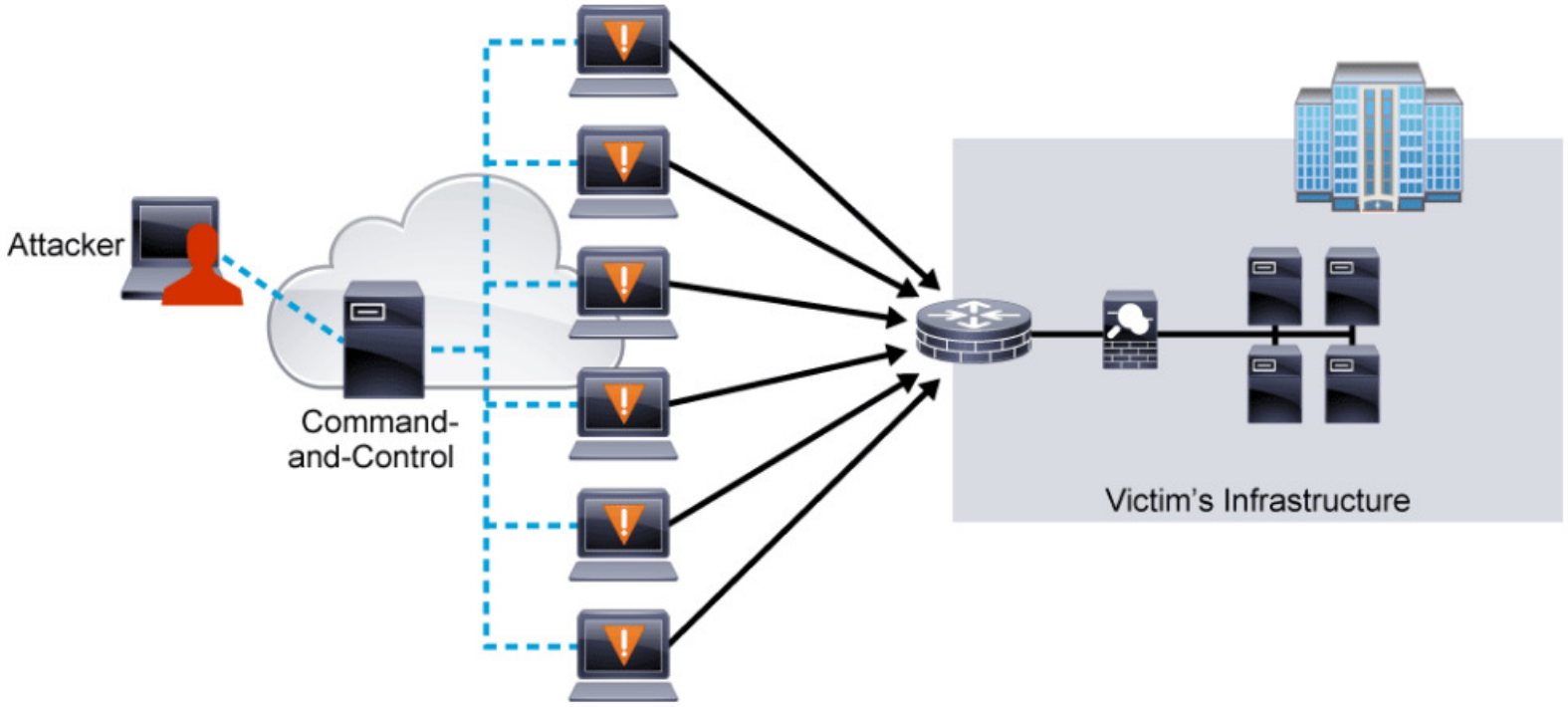
2.1 Smurf attack with spoofed source IP address

2.2 Defenses:

- Disable hosts from replying to broadcast ping
- Disable routers from supporting directed broadcast
- Apply BCP 38/RFC 2827 and anti-spoofing ACLs in routers

Another potential external attack is DoS (Denial-of-Service) or DDoS (Distributed DoS) which aims to make the target unavailable to authorised users.

Typically, DoS/DDoS aims to overload the network bandwidth or resources of the target to make it unavailable.

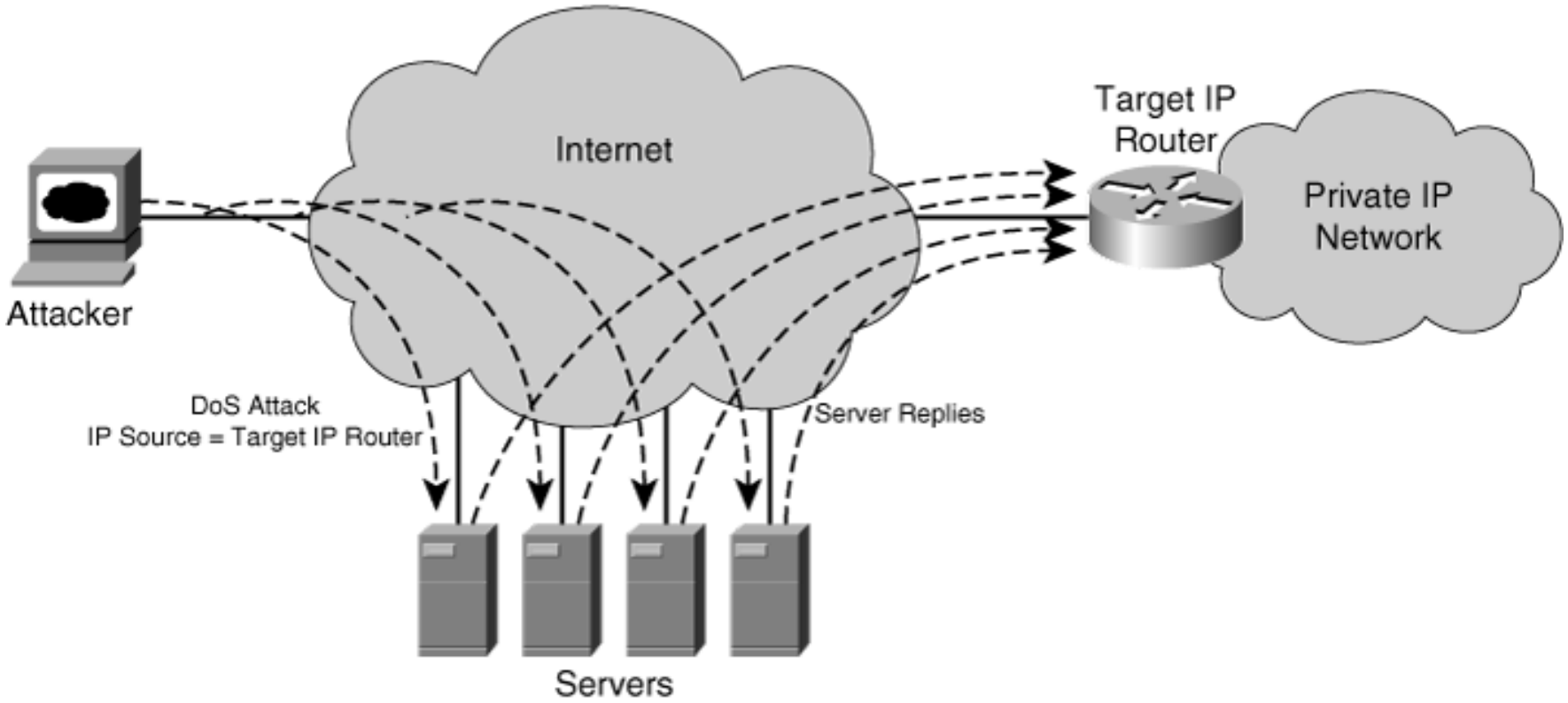


DDoS attack is basically DoS attacks that are launched using an army of compromised hosts called zombies/bots distributed in the Internet.

Broadly, DoS/DDoS attacks may be classified into 2 categories as follows:

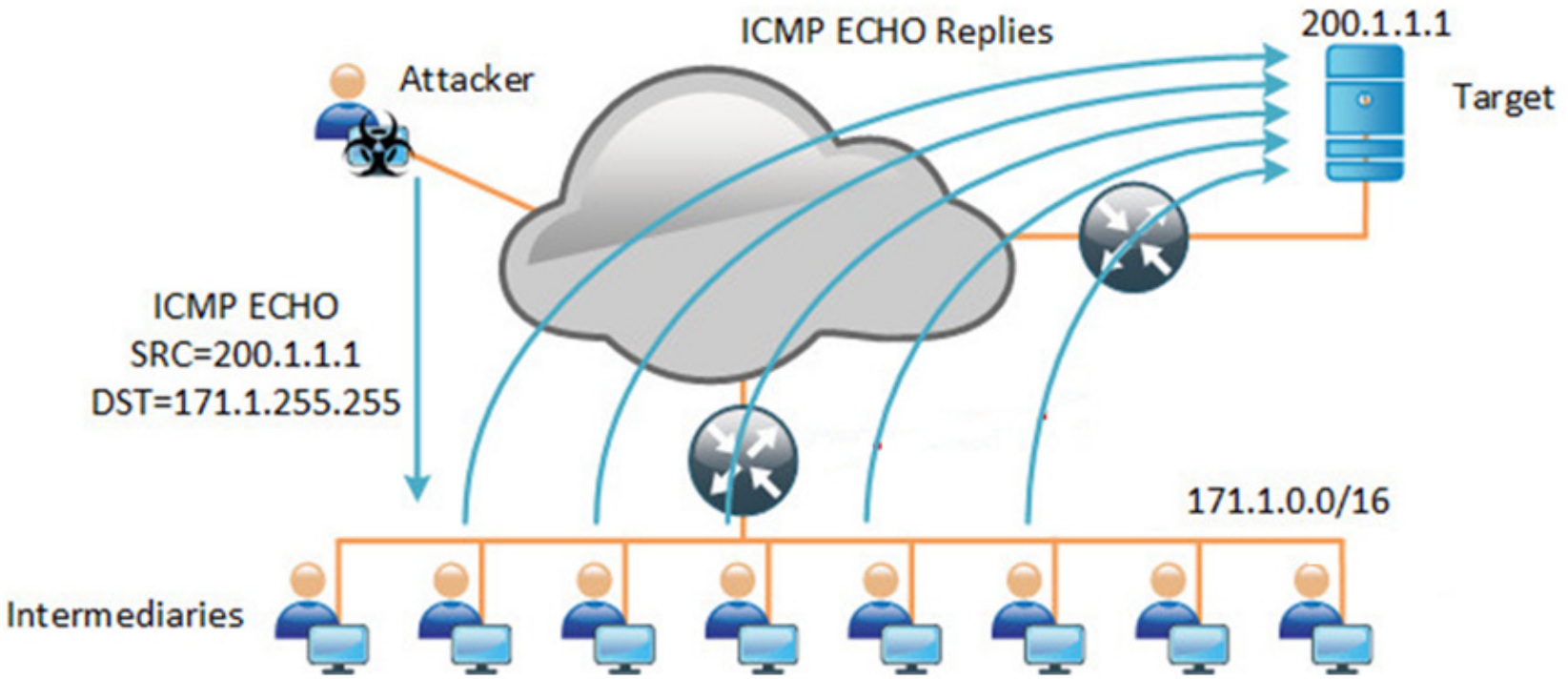
DoS/DDoS categories	Description	Typical attack packet rate	Examples
Overwhelming Quantity of Traffic	Threat actor sends an enormous quantity of data at a rate that the network, host, or application cannot handle, possibly causing slow response times or even crash a device or service.	High	ICMP flood, UDP flood, smurf attack, TCP SYN, etc
Maliciously Crafted Packets	Threat actor sends maliciously crafted packets that the host or application is not expected to handle, possibly causing it to run very slowly or even crash.	Low	Slowloris, ping of death, etc

Reflection attack is a type of DoS/DDoS which works by sending packets to intermediary servers using spoofed source IP belonging to target so that replies are reflected to attack target



If the reflection attack uses small forged packets which resulted in large replies from the intermediaries, it is also known as amplification attack; e.g. smurf attack appeared in late 1990s.

In smurf attack, a single broadcast ping sent to a directed broadcast address by attacker using spoofed IP source address belonging to target would result in multiple ping replies (each from an intermediary in the directed broadcast subnet) reflected to the target.



To have a better understanding of amplification attack, you will use hping3 in Kali Linux to try smurf attack in the lab.

```
root@kali:~# hping3 -1 --flood -a target_ip directed_broadcast_address
```

Refer *https://tools.kali.org/information-gathering/hping3* on the use of hping3:

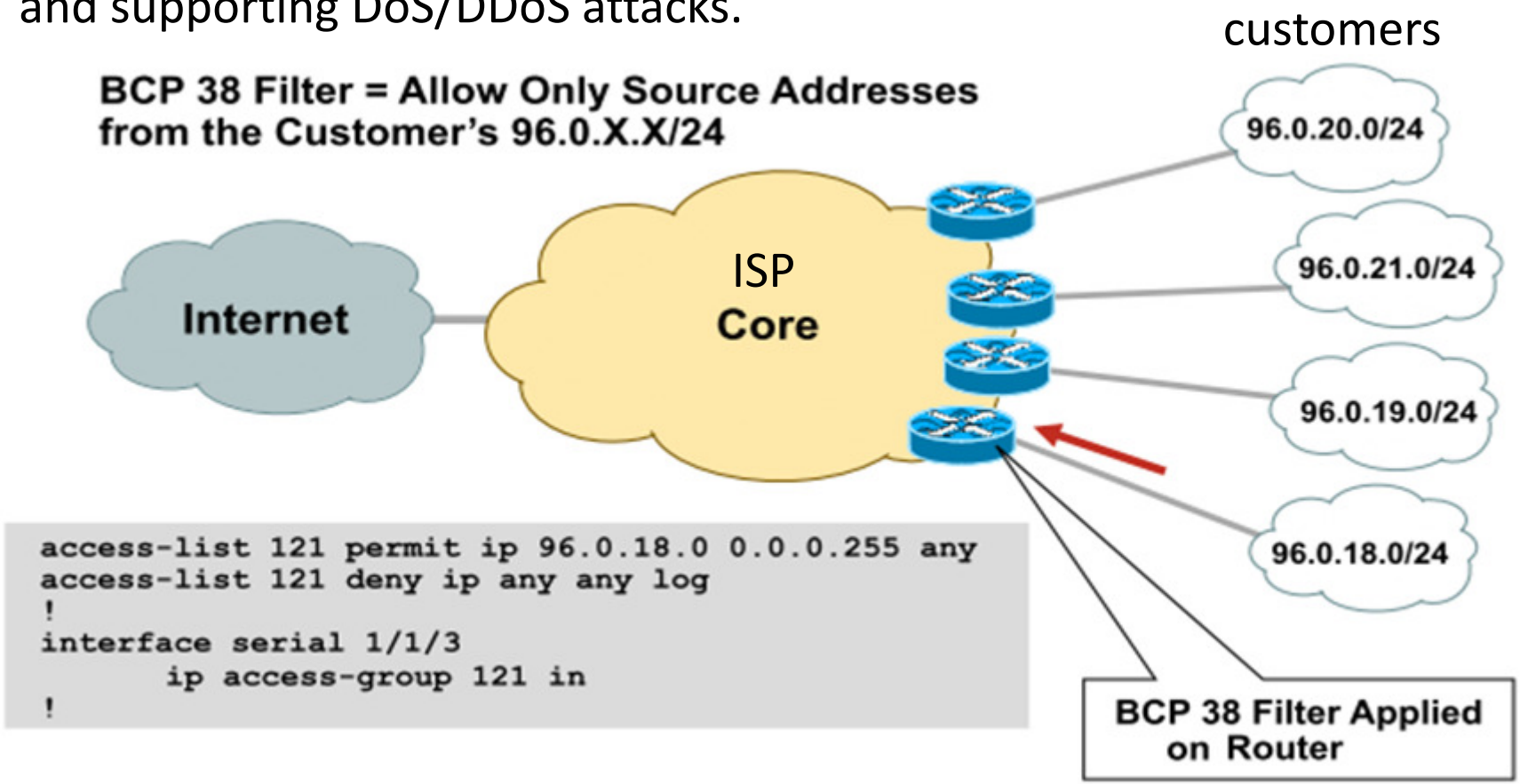
```
┌──(kali㉿kali)-[~]
└─$ hping3 --help
usage: hping3 host [options]
  -h   --help       show this help
  -v   --version    show version
  -c   --count      packet count
  -i   --interval   wait (uX for X microseconds, for example -i u1000)
       --fast       alias for -i u10000 (10 packets for second)
       --faster     alias for -i u1000 (100 packets for second)
       --flood      sent packets as fast as possible. Don't show replies.
  -n   --numeric    numeric output
  -q   --quiet      quiet
  -I   --interface  interface name (otherwise default routing interface)
  -V   --verbose    verbose mode
  -D   --debug      debugging info
  -z   --bind       bind ctrl+z to ttl           (default to dst port)
  -Z   --unbind     unbind ctrl+z
       --beep       beep for every matching packet received
Mode
  default mode      TCP
  -0   --rawip      RAW IP mode
  -1   --icmp       ICMP mode
  -2   --udp        UDP mode
  -8   --scan       SCAN mode.
                    Example: hping --scan 1-30,70-90 -S www.target.host
  -9   --listen     listen mode
IP
  -a   --spoof      spoof source address
```

Today, smurf attack has been largely prevented by default through:

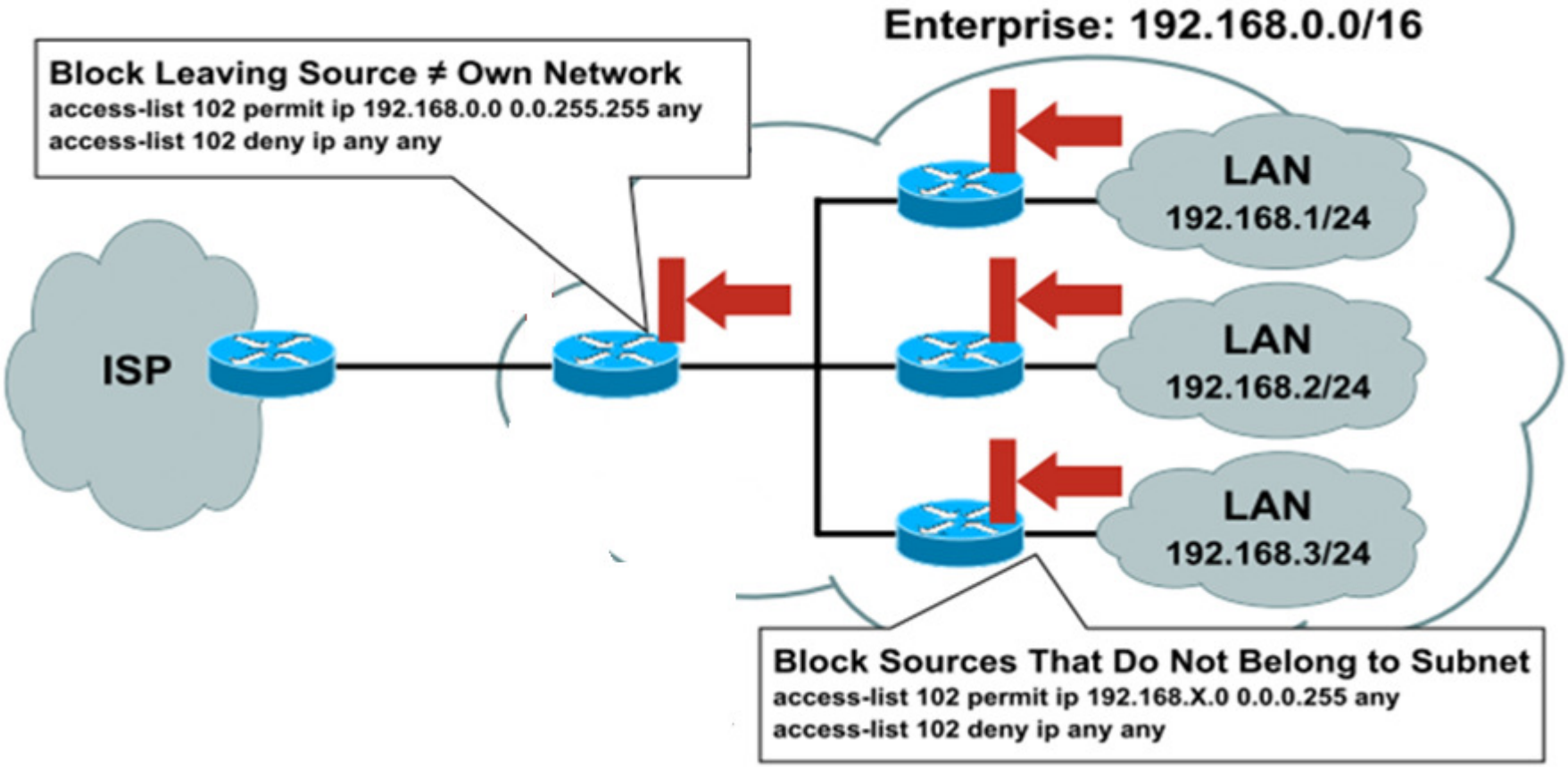
- Disable routers from supporting directed broadcast;
- Disable hosts from replying to broadcast ping.

To prevent DoS/DDoS attack using spoofed source IP addresses like smurf attack, ISPs today are recommended to implement Best Current Practice BCP 38/RFC 2827.

BCP 38/RFC 2827 recommends ISPs to implement network ingress filtering to prevent their networks from permitting spoofed IP addresses and supporting DoS/DDoS attacks.



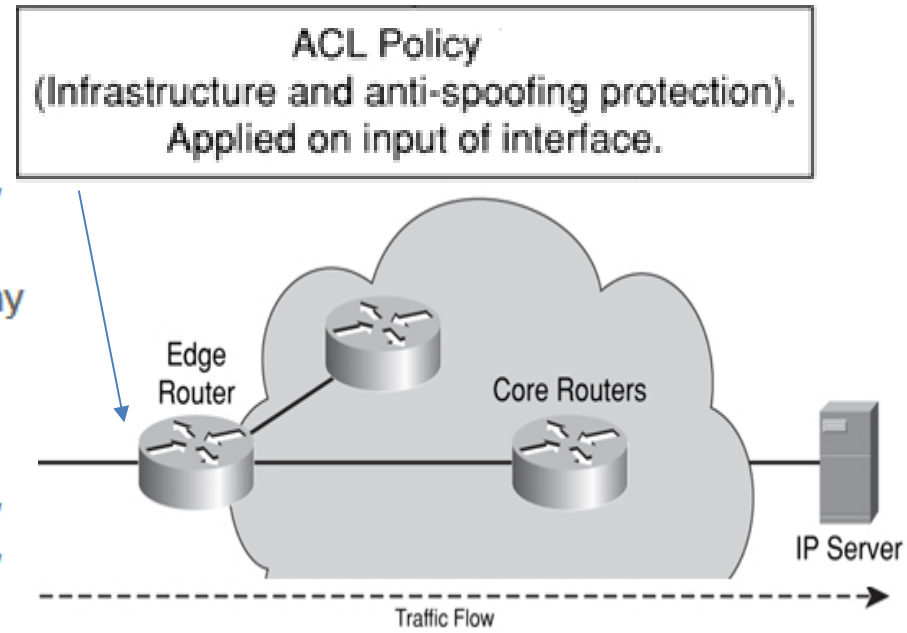
Similarly, organizations should also implement BCP 38/RFC 2827 at their edge routers to prevent their hosts, possibly zombies, from using spoofed source IP addresses to launch attacks.



In addition, organizations are recommended to implement anti-spoofing ACL at the edge router for ingress filtering of malicious traffic.

```
!--- Anti-spoofing entries are shown here.
!--- Deny RFC 3330 special-use address
access-list 110 deny ip host 0.0.0.0 any
access-list 110 deny ip 127.0.0.0 0.255.255.255 any
access-list 110 deny ip 192.0.2.0 0.0.0.255 any
access-list 110 deny ip 224.0.0.0 31.255.255.255 any

!--- Filter RFC 1918 space.
access-list 110 deny ip 10.0.0.0 0.255.255.255 any
access-list 110 deny ip 172.16.0.0 0.15.255.255 any
access-list 110 deny ip 192.168.0.0 0.0.255.255 any
```




```
!--- Deny your space as source from entering your AS. !--- Deploy only at the AS edge.
access-list 110 deny ip YOUR_CIDR_BLOCK any

!--- Deny access to internal infrastructure addresses.
access-list 110 deny ip any INTERNAL_INFRASTRUCTURE_ADDRESSES

!--- Permit transit traffic.
access-list 110 permit ip any any
```